



300-WORD PTES REPORT

1. Executive Summary

A controlled penetration test was conducted against the target environment consisting of a Kali Linux attack machine (192.168.0.103) and a Metasploitable2 host (192.168.0.139). The objective was to simulate realistic attacker behavior following the Penetration Testing Execution Standard (PTES) phases: Reconnaissance, Threat Modeling, Vulnerability Analysis, Exploitation, Post-Exploitation, and Reporting. The engagement aimed to identify critical weaknesses, demonstrate impact through exploitation, and recommend remediation.

2. Reconnaissance & Vulnerability Analysis

Using Nmap, multiple exposed services were identified, including vulnerable versions of FTP (vsftpd 2.3.4), Samba 3.0.20, Apache 2.2.8, MySQL 5.0.51a, Telnet, RSH, Postfix SMTP, and outdated RPC/NFS services. These outdated services allowed severity mapping using CVSS and prioritized testing. Manual analysis combined with automated enumeration tools identified several exploitable vectors: command execution flaws, weak authentication, insecure API endpoints, and misconfigurations.

3. Exploitation Phase

A successful exploit chain was executed using Metasploit, leveraging Samba's Usermap Script RCE to gain a shell and escalate to a Meterpreter session. A custom Python PoC was developed to simulate a buffer overflow, demonstrating exploit modification skills. API security testing uncovered BOLA and token-manipulation weaknesses. Network attacks using Responder produced NTLM hash capture, and mobile testing identified insecure storage in an APK.

4. Post-Exploitation

Meterpreter was used to enumerate users, escalate privileges using SUID misconfigurations, and establish persistence via cron. Network sniffing with Wireshark confirmed credential leakage during insecure protocol communication.

5. Remediation Plan

Patch and update outdated services, enforce least privilege, disable insecure protocols, sanitize all API input, enforce proper authentication/authorization, enable WAF, enforce ASLR/DEP, restrict SMB/FTP exposure, and implement continuous vulnerability scanning using OpenVAS.



CYART

inquiry@cyart.io

www.cyart.io